

Engenharia de Segurança do Software

Gerenciamento, Ciclo de Vida e Abordagens Ágeis

2 – Objetivos da Aula

- Compreender o conceito de Engenharia de Segurança do Software
- Entender a segurança no ciclo de vida do software
- Explorar abordagens ágeis aplicadas à segurança
- Identificar práticas de segurança em ambientes ágeis
- Aplicar métodos e ferramentas para mapeamento de RNFs

3 – O que é Engenharia de Segurança do Software?

- . Área da Engenharia de Software focada na proteção de sistemas
- . Integra segurança desde a fase de requisitos
- . Busca prevenir vulnerabilidades
- . Envolve pessoas, processos e tecnologia
 - **Objetivo principal:** Garantir confidencialidade, integridade e disponibilidade (CIA).

4 – Princípios da Segurança da Informação

- Confidencialidade
- Integridade
- Disponibilidade
- Autenticidade
- Não repúdio

5 – Segurança no Ciclo de Vida do Software (SDLC)

- Modelo tradicional:
 1. Levantamento de requisitos
 2. Projeto
 3. Implementação
 4. Testes
 5. Implantação
 6. Manutenção
- Segurança deve estar presente em todas as fases.

6 – Secure SDLC

- . Integra práticas de segurança no desenvolvimento
- . Reduz custo de correção de falhas
- . Antecipação de riscos
- Exemplos de modelos:
 - . OWASP ([Open Web Application Security Project](#))
 - . Microsoft SDL (Security Development Lifecycle)

7 – Gerenciamento de Segurança no Ciclo de Vida

- **Inclui:**
- **Análise de riscos**
- **Definição de políticas de segurança**
- **Controle de acesso**
- **Testes de segurança**
- **Monitoramento contínuo**
- **Ferramentas comuns:**
- **SAST (Static Application Security Testing)**
- **DAST (Dynamic Application Security Testing)**

8 – Abordagens Ágeis e Segurança

- **Metodologias Ágeis:**
 - **Scrum**
 - **Extreme Programming**
- **Características:**
 - **Iterações curtas**
 - **Entregas incrementais**
 - **Feedback contínuo**
- **Desafio: integrar segurança sem comprometer velocidade.**

9 – DevSecOps

- **Evolução do DevOps:**
 - **DevOps → Integra desenvolvimento e operações**
 - **DevSecOps → Segurança integrada ao pipeline**
- **Princípios:**
 - **Automação de testes de segurança**
 - **Monitoramento contínuo**
 - **Cultura colaborativa**

10 – Práticas de Segurança em Ambientes Ágeis

- . User Stories de Segurança**
- . Security Backlog**
- . Definition of Done com critérios de segurança**
- . Revisão de código (Code Review)**
- . Testes automatizados de segurança**
- . Integração contínua com análise de vulnerabilidades**

11 – Threat Modeling (Modelagem de Ameaças)

- . Identificação de ameaças antes da implementação**
- . Análise de vetores de ataque**
- . Avaliação de impacto**
- Modelo comum:**
- STRIDE (Microsoft)**

12 – Requisitos Não Funcionais (RNF)

- **RNFs relacionados à segurança:**
 - **Autenticação**
 - **Autorização**
 - **Criptografia**
 - **Auditoria**
 - **Conformidade (LGPD, ISO 27001)**

13 – Mapeamento de RNFs

- **Técnicas:**
 - **Checklists de segurança**
 - **Catálogos de RNFs**
 - **Entrevistas com stakeholders**
 - **Análise de riscos**
- **Ferramentas de apoio:**
 - **OWASP ASVS**
 - **ISO/IEC 27001**

14 – Exemplo Prático

- **Sistema: E-commerce**
- **RNFs de Segurança:**
 - . **Login com autenticação multifator**
 - . **Criptografia de dados sensíveis**
 - . **Registro de logs de auditoria**
 - . **Proteção contra SQL Injection**

15 – Ferramentas de Apoio

- . SonarQube (análise estática)**
- . Burp Suite (teste de intrusão)**
- . GitHub Security**
- . OWASP ZAP**

16 – Desafios Atuais

- . Cultura organizacional**
- . Pressão por entregas rápidas**
- . Falta de especialistas em segurança**
- . Atualizações constantes de ameaças**

17 – Boas Práticas

- **✓ Segurança desde o início (Shift Left)**
 - ✓ Automação**
 - ✓ Capacitação contínua**
 - ✓ Monitoramento constante**
 - ✓ Cultura DevSecOps**

18 – Conclusão

- . Segurança é responsabilidade de todos**
- . Deve estar integrada ao ciclo de vida**
- . Abordagens ágeis exigem automação e cultura**
- . RNFs são fundamentais para garantir proteção adequada**

19 – Perguntas

•Dúvidas? Discussões?